

Security+ SY0-701 Memorization Sheet

Print this and keep it beside you while you study. Security+ is a vocabulary exam: most questions describe a situation and ask for the exact term, control, or next step. Every table here is fair game.

01 The exam itself

FACT	VALUE
Exam code	SY0-701 (Security+)
Questions	Up to 90, multiple choice plus performance-based
Time	90 minutes
Passing score	750 on a scale of 100 to 900 (about 83%)
1.0 General Security Concepts	12%
2.0 Threats, Vulnerabilities, and Mitigations	22%
3.0 Security Architecture	18%
4.0 Security Operations	28%
5.0 Security Program Management and Oversight	20%

Read for the qualifier: BEST, MOST likely, FIRST, NEXT, LEAST. Many answers are 'the least disruptive control that fixes the stated problem.'

02 Security controls and core concepts

CONTROL CATEGORY	WHO OR WHAT APPLIES IT	EXAMPLES
Technical	Systems and software	Firewalls, encryption, IDS, ACLs, MFA
Managerial	Policy and oversight	Risk assessments, security policies, awareness program planning
Operational	People carrying out procedures	Guards, awareness training delivery, incident response steps, backups
Physical	The building and hardware	Locks, fences, bollards, badges, cameras, lighting

CONTROL TYPE	PURPOSE	EXAMPLES
Preventive	Stop it before it happens	Firewall rule, door lock, least privilege
Deterrent	Discourage the attempt	Warning signs, visible cameras, login banners
Detective	Notice it happened	IDS, logs, audits, motion sensors, cameras reviewed later
Corrective	Undo the damage	Restore from backup, patch after incident, incident response
Compensating	Alternative when the ideal control is not possible	Extra monitoring on a system that cannot be patched
Directive	Tell people what to do	Policies, procedures, acceptable use, signage

- CIA: **Confidentiality** (encryption, access control), **Integrity** (hashing, signatures, change control), **Availability** (redundancy, backups, DDoS protection)
 - Non-repudiation**: the sender cannot deny sending; digital signatures
- AAA: **Authentication** (who you are), **Authorization** (what you may do), **Accounting** (what you did). Authenticating systems as well as people (certificates, 802.1X)
 - Gap analysis**: where you are versus where the framework or policy says you should be

- **Deception:** honeypot (decoy system), honeynet (decoy network), honeyfile (bait document), honeytoken (fake credential or record that alerts when used)

ZERO TRUST COMPONENT	PLANE	JOB
Policy engine	Control plane	Decides allow or deny for each request
Policy administrator	Control plane	Tells the enforcement point what the engine decided
Adaptive identity	Control plane	Authentication strength changes with context (location, device, behavior)
Threat scope reduction	Control plane	Limit what any identity can reach
Policy-driven access control	Control plane	Rules, not network location, grant access
Policy enforcement point	Data plane	Where the allow or deny is applied to traffic
Implicit trust zones	Data plane	Small zones where traffic is allowed after verification
Subject and system	Data plane	The user or device asking, and the resource

Physical security

- Bollards stop vehicles. Fencing sets the perimeter. Lighting deters and helps cameras
- Access control vestibule (mantrap): two doors, one opens at a time, stops tailgating
- Access badge, security guard, video surveillance
- Sensors: **infrared** (body heat), **pressure** (weight on a floor or mat), **microwave** (motion by reflected waves), **ultrasonic** (motion by sound)

03 Change management

- Business process: approval process, ownership, stakeholders, impact analysis, test results, backout plan, maintenance window, standard operating procedure
- Technical implications: allow lists and deny lists, restricted activities, downtime, service and application restarts, legacy applications, dependencies
- Documentation: update diagrams, policies, and procedures. Version control tracks every change and lets you roll back
- Order in a question: request and impact analysis, approval, schedule the window, test, implement with a backout plan ready, document

04 Cryptography

CONCEPT	DETAIL
Symmetric	One shared key encrypts and decrypts. Fast, bulk data. AES (128, 192, 256-bit), 3DES (legacy), ChaCha20, Blowfish
Asymmetric	Public key encrypts or verifies, private key decrypts or signs. Slow, used for key exchange and signatures. RSA, ECC (smaller keys, same strength), DSA, ECDSA
Key exchange	Diffie-Hellman and ECDHE agree on a shared key over an open channel. Ephemeral keys give perfect forward secrecy
Hashing	One-way fixed-length fingerprint: MD5 128-bit (broken), SHA-1 160-bit (deprecated), SHA-256, SHA-3. HMAC adds a key for authenticity
Salting	Random data added to a password before hashing so identical passwords hash differently and rainbow tables fail
Key stretching	Make hashing slow on purpose: PBKDF2, bcrypt, scrypt, Argon2
Digital signature	Hash the message, encrypt the hash with the private key. Proves integrity, authenticity, and non-repudiation
Key length	Longer is stronger; AES-256 over AES-128, RSA 2048 minimum, ECC 256 is comparable to RSA 3072
Blockchain	Open public ledger: chained hashed blocks, tamper-evident, distributed

CONCEPT	DETAIL
Transport encryption	TLS 1.2 and 1.3 for web and mail, IPsec for VPNs, SSH for shells. Deprecated: SSL, TLS 1.0 and 1.1

ENCRYPTION LEVEL	WHAT IS PROTECTED
Full-disk	The whole drive; protects a lost laptop
Partition or volume	One partition or logical volume
File	Individual files
Database	The whole database
Record	Individual fields or rows, such as card numbers

Tools and obfuscation

- **TPM:** chip on the motherboard that stores keys and measures boot; used by full-disk encryption
- **HSM:** dedicated hardware appliance or card for key storage and crypto operations at scale
- **KMS:** key management service, usually cloud, for creating, rotating, and controlling keys
- **Secure enclave:** isolated processor area for secrets on phones and laptops
- **Key escrow:** a trusted third party holds a copy of the key for recovery
- **Steganography** hides data inside images or audio. **Tokenization** replaces data with a token mapped in a vault. **Data masking** shows only part (xxxx-1234)

PKI TERM	MEANING
Certificate authority (CA)	Issues and signs certificates; the root of trust
Registration authority	Verifies identity before the CA issues
CSR	Certificate signing request: the public key plus identity sent to the CA
CRL	Certificate revocation list, downloaded periodically; can be stale
OCSP	Real-time revocation check of one certificate; OCSP stapling has the server include a fresh response
Self-signed	Not signed by a trusted CA; browsers warn; internal use only
Third-party	Issued by a public CA; trusted by browsers
Wildcard	*.example.com covers every subdomain at one level
SAN	Subject alternative name: several names on one certificate
Formats	PEM (Base64 text, .crt .pem), DER (binary), PFX or P12 (with private key), P7B (chain, no private key)

05 Threat actors, vectors, and social engineering

ACTOR	TYPICAL TRAITS	TYPICAL MOTIVATION
Nation-state	External, well funded, highly sophisticated, patient (APT)	Espionage, war, disruption
Organized crime	External, funded, sophisticated	Financial gain: ransomware, fraud
Hacktivist	External, modest resources	Philosophical or political, service disruption
Insider threat	Internal, has access already	Revenge, financial gain, or accidental
Unskilled attacker	External, low sophistication, uses others' tools	Chaos, notoriety
Shadow IT	Internal, not malicious	Convenience; creates unmanaged risk

Motivations to recognize

- Data exfiltration, espionage, service disruption, blackmail, financial gain, philosophical or political beliefs, ethical (white hat), revenge, disruption or chaos, war

VECTOR	EXAMPLES
Message-based	Email, SMS, instant messaging
Image-based and file-based	Malicious images, macros in documents, executables
Voice call	Vishing
Removable device	USB drops
Vulnerable software	Client-based (agent installed) versus agentless
Unsupported systems	End-of-life operating systems and applications
Insecure networks	Open wireless, unmanaged wired ports, Bluetooth
Open service ports, default credentials	Exposed services, unchanged admin passwords
Supply chain	Managed service providers, vendors, suppliers

HUMAN VECTOR	ONE-LINE DEFINITION
Phishing	Fraudulent email to steal credentials or deliver malware
Vishing, smishing	The same by voice call, by text message
Spear phishing, whaling	Targeted at a person; targeted at an executive
Business email compromise	Attacker uses or imitates a real business account to redirect payments
Pretexting	An invented story that justifies the request
Impersonation, brand impersonation	Pretending to be a person; pretending to be a company
Watering hole	Compromise a site the targets already visit
Typosquatting	Look-alike domain names catching mistyped URLs
Misinformation, disinformation	False content spread unknowingly; spread deliberately
Tailgating, shoulder surfing, dumpster diving	Following through a door; watching a screen; reading the trash

06 Vulnerabilities

CLASS	MEMBERS TO RECOGNIZE
Application	Memory injection, buffer overflow, race conditions (time-of-check to time-of-use), malicious update
Operating system	Unpatched services, weak defaults
Web-based	SQL injection (' OR 1=1), cross-site scripting (script in a page other users load)
Hardware	Firmware flaws, end-of-life, legacy devices
Virtualization	VM escape (guest reaches the host), resource reuse (data left in reallocated memory or storage)
Cloud-specific	Misconfigured storage, shared-tenant risks, exposed APIs
Supply chain	Service provider, hardware provider, software provider
Cryptographic	Weak or deprecated algorithms, short keys, bad implementations
Misconfiguration	Open ports, default settings, excessive permissions

CLASS	MEMBERS TO RECOGNIZE
Mobile	Side loading (apps from outside the store), jailbreaking or rooting
Zero-day	Known to attackers before a patch exists

07 Attacks and indicators

MALWARE	TELL	
Ransomware	Files encrypted, payment demanded	
Trojan	Hidden inside a wanted program; remote access trojan gives control	
Worm	Spreads by itself across the network	
Virus	Attaches to files, needs a user action to spread	
Spyware, keylogger	Watches activity; records keystrokes	
Bloatware	Unwanted preinstalled software, expands attack surface	
Logic bomb	Triggers on a date or event	
Rootkit	Hides at kernel or firmware level; survives reboots, evades antivirus	

ATTACK	TELL	DEFENSE
DDoS (amplified, reflected)	Floods from many sources; small requests to third parties produce large responses at the victim	Upstream scrubbing, rate limiting
DNS attacks	Poisoned cache, spoofed answers, domain hijacking	DNSSEC, DNS filtering
Wireless attacks	Evil twin, deauthentication, rogue AP	WPA3, 802.1X, protected management frames
On-path	Attacker between the parties reads or alters traffic	TLS, VPN, certificate pinning
Credential replay	Captured authentication reused	Session tokens, nonces, MFA
Injection	Untrusted input executed by a database, shell, or LDAP	Input validation, parameterized queries
Buffer overflow	Input longer than the buffer overwrites memory	Patching, memory-safe code, ASLR
Privilege escalation	Normal user gains admin	Least privilege, patching
Forgery (CSRF, SSRF)	Victim's browser or the server is tricked into making a request	Anti-forgery tokens, input validation
Directory traversal	../ in a path reaches files outside the web root	Input validation, least privilege
Downgrade	Forces a weaker protocol or cipher	Disable legacy protocols
Collision, birthday	Two inputs with the same hash; probability grows fast with attempts	Strong hashes (SHA-256+)
Password spraying	One common password tried against many accounts	MFA, lockout tuned for spraying
Brute force	Every combination against one account	Lockout, length, MFA
RFID cloning, brute force on locks, environmental	Physical attacks	Physical controls, monitoring

Indicators of malicious activity

- Account lockout, concurrent session usage, impossible travel (logins from two distant places in minutes)
- Blocked content, resource consumption spikes, resources becoming inaccessible

- Out-of-cycle logging, missing logs (attacker cleared them), published or documented exploits for your versions

Mitigation techniques

- Segmentation; access control (ACLs, permissions); application allow lists; isolation; patching; encryption; monitoring; least privilege; configuration enforcement; decommissioning
- Hardening: encryption, endpoint protection, host-based firewall, host-based IPS, disable unused ports and protocols, change default passwords, remove unnecessary software

08 Security architecture

Architecture models

- Cloud **responsibility matrix**: the provider secures the infrastructure; the customer secures data, identities, and configuration. Hybrid and third-party vendors add shared responsibility
- **Infrastructure as code**: environments defined in files; **serverless**: provider runs the function; **microservices**: many small services with APIs
- Network: **physical isolation (air gap)**, **logical segmentation** (VLANs, subnets), **software-defined networking**
- On-premises versus cloud; centralized versus decentralized; **containerization** (shared kernel) versus **virtualization** (hypervisor)
- **IoT**, **ICS/SCADA** (industrial control), **RTOS** (real-time), **embedded** systems: hard to patch, isolate them
- Considerations: availability, resilience, cost, responsiveness, scalability, ease of deployment, risk transference, ease of recovery, patch availability, inability to patch, power, compute

INFRASTRUCTURE CONCEPT	DETAIL
Security zones	Trusted, untrusted, screened subnet (DMZ) for public-facing servers
Attack surface	Everything reachable; shrink it
Fail-open versus fail-closed	Fail-open keeps traffic flowing when the control fails (availability); fail-closed blocks (security)
Active versus passive	Inline (can block, can bottleneck) versus tap or monitor port (sees a copy, alerts only)
Jump server	Hardened host you go through to reach protected systems
Proxy server	Forward proxy for clients; reverse proxy in front of servers
IPS versus IDS	Inline and blocks versus out of band and alerts
Load balancer	Spreads traffic; active-active or active-passive
Sensors	Collect traffic or logs for monitoring
Port security	802.1X authentication on switch ports and Wi-Fi, using EAP (EAP-TLS with certificates is strongest; PEAP, EAP-TTLS, EAP-FAST)
Firewall types	WAF (Layer 7, protects web apps), UTM (all-in-one), NGFW (application-aware, user-aware), Layer 4 (ports) versus Layer 7 (content)
Secure communication	VPN and remote access; tunneling with TLS or IPsec; SD-WAN; SASE (network plus cloud security)

09 Data protection

DATA TYPE	MEANING
Regulated	Law or regulation governs it: health, payment card, personal data
Trade secret, intellectual property	Formulas, source code, designs

DATA TYPE	MEANING
Legal information, financial information	Contracts, litigation; ledgers, filings
Human-readable versus non-human-readable	Documents versus binaries and encrypted blobs

CLASSIFICATION	TYPICAL USE
Public	Anyone may see it
Private, sensitive	Internal; harm if leaked
Confidential	Limited to those who need it
Restricted	Tightly controlled, often regulated
Critical	The organization cannot function without it

States: at rest (disk, database), in transit (network), in use (memory, being processed)	Data sovereignty: data is subject to the laws of the country where it is stored. Geolocation and geographic restrictions control where data may live or be accessed from - Methods: encryption, hashing, masking, tokenization, obfuscation, segmentation, permission restrictions
---	--

10 Resilience and recovery

CONCEPT	DETAIL
Load balancing versus clustering	Spreads requests across servers; servers act as one system with failover
Hot site	Running mirror, minutes to switch, most expensive
Warm site	Equipment ready, data restored on failover, hours
Cold site	Space and power only, days
Geographic dispersion	Sites far enough apart that one disaster cannot hit both
Platform diversity, multi-cloud	Different vendors so one flaw or outage does not take everything
Continuity of operations	Keep the business running through the incident
Capacity planning	People, technology, infrastructure sized for growth and surge
Testing	Tabletop (talk through), failover (actually switch), simulation (drill), parallel processing (run both and compare)
Backups	Onsite and offsite, frequency, encryption, snapshots, replication, journaling (log every change), tested recovery
Full, incremental, differential	Everything; changes since the last backup of any kind (small, slow restore); changes since the last full (bigger, faster restore)
Power	UPS bridges to the generator; generator for long outages

RAID	HOW IT WORKS	SURVIVES
RAID 0	Striping, no redundancy	Nothing; speed only
RAID 1	Mirroring	One disk failure
RAID 5	Striping with distributed parity, 3+ disks	One disk
RAID 6	Striping with double parity, 4+ disks	Two disks
RAID 10	Mirrored pairs, striped	One disk per mirror

11 Securing resources and monitoring

Baselines, hardening, wireless, mobile, applications

- Secure baseline: **establish** it, **deploy** it, **maintain** it (drift detection)
- Hardening targets: mobile devices, workstations, switches, routers, cloud infrastructure, servers, ICS/SCADA, embedded and RTOS, IoT
- Wireless: site survey and heat map first; WPA3; enterprise authentication with AAA and RADIUS; EAP-TLS strongest
- Mobile: **MDM** enforces policy; deployment models **BYOD** (personal), **COPE** (company owned, personally enabled), **CYOD** (choose from a list); connections cellular, Wi-Fi, Bluetooth
- Application security: input validation, secure cookies, static code analysis, code signing; **sandboxing** runs untrusted code in isolation

Asset management

- Acquisition and procurement, assignment and ownership, classification, monitoring and asset tracking (inventory, enumeration)
- Disposal: **sanitization** (wipe so data cannot be recovered), **destruction** (shred, degauss, pulverize), **certification** (proof it was done), **data retention** rules first

VULNERABILITY MANAGEMENT STEP	CONTENTS
Identification	Vulnerability scans (credentialed sees more), application analysis static and dynamic, package monitoring, threat feeds (OSINT, proprietary, ISACs, dark web), penetration testing, responsible disclosure and bug bounty, system and process audits
Analysis	Confirm (false positive, false negative), prioritize with CVSS and CVE, classification, exposure factor, environmental variables, industry and organizational impact, risk tolerance
Response	Patch, cyber insurance, segmentation, compensating controls, documented exceptions and exemptions
Validation	Rescan, audit, verify
Reporting	Trends, open items, time to remediate

CVSS RATING	SCORE
None	0.0
Low	0.1 to 3.9
Medium	4.0 to 6.9
High	7.0 to 8.9
Critical	9.0 to 10.0

Monitoring tools

- Log aggregation, alerting, scanning, reporting, archiving; alert response and remediation (quarantine); alert tuning to cut false positives
- SCAP**: automated compliance checking against benchmarks (CIS). Agents versus agentless collection
- SIEM** correlates logs; **antivirus**; **DLP** stops data leaving; **SNMP traps** push device alerts; **NetFlow** shows who talked to whom; **vulnerability scanners**

ENTERPRISE CAPABILITY	ONE-LINE JOB
Firewall rules, access lists, ports and protocols, screened subnets	Allow only what is needed between zones
IDS/IPS trends and signatures	Detect known patterns; tune for trends
Web filter	Agent-based or centralized proxy; URL scanning, content categorization, block rules, reputation

ENTERPRISE CAPABILITY	ONE-LINE JOB
Operating system security	Group Policy on Windows, SELinux on Linux
Secure protocols	Pick the encrypted port and transport: SSH not Telnet, HTTPS not HTTP, SFTP not FTP, SNMPv3, LDAPS, DoH or DoT
DNS filtering	Block known-bad domains at resolution
Email security	SPF (allowed senders), DKIM (signed mail), DMARC (policy for failures), email gateway
File integrity monitoring	Alert when critical files change
DLP	Prevent sensitive data from leaving by email, USB, or upload
NAC	Check device health before granting network access
EDR and XDR	Endpoint detection and response; extended across network and cloud
User behavior analytics	Baseline each user, alert on deviation

12 Identity and access management

CONCEPT	DETAIL
Provisioning and deprovisioning	Create access on hire, remove it on exit; the classic offboarding failure is a still-active account
Identity proofing	Verify a person is who they claim before issuing credentials
Federation	One organization trusts another's identities
SSO protocols	SAML (XML, enterprise web SSO), OAuth (authorization delegation), OpenID Connect (authentication on OAuth), LDAP (directory), Kerberos (tickets, Windows domains)
Attestation	Confirming that a device or account state is what it claims

ACCESS CONTROL MODEL	RULE
Mandatory (MAC)	Labels and clearances set by the system; users cannot change them; military
Discretionary (DAC)	The owner decides who gets access; file permissions
Role-based (RBAC)	Permissions attach to roles, users to roles
Rule-based	Fixed rules such as firewall ACLs or time limits
Attribute-based (ABAC)	Decisions from attributes: department, location, device, time
Time-of-day restrictions	Access only during set hours
Least privilege	Only what the job needs

MFA and passwords

- Factors: **something you know** (password, PIN), **something you have** (token, phone, smart card, security key), **something you are** (biometrics), **somewhere you are** (location)
- Tokens: hard (device), soft (app), security keys (FIDO2). Biometrics have false acceptance and false rejection rates
- Password policy: length beats complexity, no reuse, expiration and age rules, password managers, **passwordless** with keys or biometrics
- Privileged access management**: just-in-time permissions, password vaulting, ephemeral (temporary) credentials

Automation and orchestration

- Use cases: user and resource provisioning, guard rails, security groups, ticket creation and escalation, enabling and disabling services, continuous integration and testing, integrations and APIs
- Benefits: efficiency, enforced baselines, secure scaling, employee retention, reaction time, workforce multiplier
- Considerations: complexity, cost, single point of failure, technical debt, ongoing supportability

13 Incident response and forensics

Incident response process, in order

- 1. Preparation: plans, tools, training, contacts.
- 2. Detection: notice that something happened.
- 3. Analysis: confirm and scope it.
- 4. Containment: stop the spread (isolate, block).
- 5. Eradication: remove the cause (malware, accounts, vulnerability).
- 6. Recovery: restore systems and monitor.
- 7. Lessons learned: review and improve.
- Training and testing: tabletop exercises and simulations
- **Root cause analysis** finds why, not just what. **Threat hunting** searches proactively for signs an alert missed
- Forensics: **legal hold** (preserve, do not delete), **chain of custody** (who handled evidence, when), **acquisition** (image it), **preservation, reporting, e-discovery**
- Order of volatility (collect first): CPU cache and registers, RAM, swap and temporary files, disk, remote logs, archives and backups

DATA SOURCE	WHAT IT TELLS YOU
Firewall logs	Allowed and blocked connections
Application logs	Errors, logins, transactions
Endpoint logs	Processes, files, EDR alerts
OS-specific logs	Windows Event logs, Linux syslog and auth logs
IPS/IDS logs	Matched signatures
Network logs, metadata	Flows, DNS, headers
Vulnerability scans, automated reports, dashboards, packet captures	State, trends, and raw evidence

14 Governance, risk, and compliance

DOCUMENT	WHAT IT IS	EXAMPLES
Policy	What must be done, high level	Acceptable use, information security, business continuity, disaster recovery, incident response, SDLC, change management
Standard	Specific mandatory settings	Password, access control, physical security, encryption
Procedure	Step by step how	Change management steps, onboarding and offboarding, playbooks
Guideline	Recommended, not mandatory	Best-practice advice

- External considerations: regulatory, legal, industry, local and regional, national, global. Monitoring and revision keep documents current
- Governance structures: boards, committees, government entities; centralized versus decentralized

- Data roles: **owner** (accountable), **controller** (decides why and how personal data is processed), **processor** (processes on the controller's behalf), **custodian or steward** (day-to-day handling and quality)

RISK TERM	DEFINITION OR FORMULA
Asset value (AV)	What the asset is worth
Exposure factor (EF)	Fraction of value lost in one incident
Single loss expectancy	$SLE = AV \times EF$
Annualized rate of occurrence (ARO)	How many times per year
Annualized loss expectancy	$ALE = SLE \times ARO$
Qualitative versus quantitative	High/medium/low ratings versus dollars and probabilities
Assessment cadence	Ad hoc, recurring, one-time, continuous
Risk register	List of risks with key risk indicators, owners, and thresholds
Risk tolerance and appetite	How much variance is acceptable; appetite is expansionary, conservative, or neutral
Strategies	Transfer (insurance), accept (with exemption or exception), avoid (stop the activity), mitigate (add controls)
Business impact analysis	RTO (time to restore), RPO (data loss allowed), MTTR (mean repair time), MTBF (mean time between failures)

AGREEMENT	USE
SLA	Measurable service levels and penalties
MOA, MOU	Agreement of intent; MOU less formal
MSA	Master agreement covering the relationship; work orders hang off it
WO / SOW	Work order or statement of work for one job
NDA	Confidentiality
BPA	Business partnership agreement: profits, responsibilities

Third-party risk

- Vendor assessment: penetration testing, right-to-audit clause, evidence of internal audits, independent assessments, supply chain analysis
- Vendor selection: due diligence, conflict of interest. Ongoing: monitoring, questionnaires, rules of engagement

Compliance and privacy

- Reporting: internal and external. Consequences: fines, sanctions, reputational damage, loss of license, contractual impacts
- Monitoring: due diligence and due care, attestation and acknowledgement, internal and external, automation
- Privacy: legal implications at local, regional, national, global levels; data subject; controller versus processor; ownership; data inventory and retention; right to be forgotten

Audits, assessments, penetration testing

- Attestation; internal (compliance, audit committee, self-assessments); external (regulatory, examinations, assessment, independent third-party audit)
- Pen test types: physical, offensive (red), defensive (blue), integrated (purple)
- Environment knowledge: **known** (full information, white box), **partially known** (some, gray box), **unknown** (none, black box)
- Reconnaissance: **passive** (public sources, no contact) versus **active** (scanning the target)

Security awareness

- Phishing campaigns and recognizing and reporting attempts; anomalous behavior recognition (risky, unexpected, unintentional)
- User guidance: policies and handbooks, situational awareness, insider threat, password management, removable media and cables, social engineering, operational security, hybrid and remote work
- Reporting and monitoring: initial and recurring; program development and execution

15 Ports and secure protocol pairs

INSECURE	PORT	SECURE REPLACEMENT	PORT
HTTP	80	HTTPS (TLS)	443
FTP	20, 21	SFTP (over SSH); FTPS	22; 989, 990
Telnet	23	SSH	22
SMTP	25	SMTPS or submission with TLS	465, 587
POP3	110	POP3S	995
IMAP	143	IMAPS	993
LDAP	389	LDAPS	636
SNMP v1, v2c	161, 162	SNMPv3 (same ports, adds auth and encryption)	161, 162
DNS	53	DNS over TLS; DNS over HTTPS	853; 443
NTP	123	NTS	123
RTP (voice)	dynamic	SRTP	dynamic
SIP	5060	SIP over TLS	5061

- Other ports: DHCP 67/68, TFTP 69, Kerberos 88, RDP 3389, SMB 445, syslog 514, RADIUS 1812/1813, TACACS+ TCP 49, SQL Server 1433, MySQL 3306, IKE 500 and NAT-T 4500
- IPsec: **AH** integrity only, **ESP** encryption, **IKE** negotiates keys; transport mode protects the payload, tunnel mode wraps the whole packet
- Email authentication: **SPF** lists allowed sending servers, **DKIM** signs messages, **DMARC** says what to do when they fail
- Wireless: WEP broken, WPA deprecated, WPA2 AES, WPA3 SAE; enterprise mode uses 802.1X with RADIUS